

Introduction to Lab

As we progress through the module, we will practice identifying and exploiting each of the OWASP API Top 10 vulnerabilities in the **RESTful** web API to fully understand these vulnerabilities.

Inlanefreight E-Commerce Marketplace

Our loyal customer, Inlanefreight, has ventured into the world of e-commerce marketplaces with **Inlanefreight E-Commerce Marketplace**. The marketplace's business model enables customers to browse and purchase products of various types, each of which is associated with a specific company. The marketplace generates revenue by charging a fee for each product sold by a supplier.

To operate the marketplace and facilitate transactions between customers and suppliers, Inlanefreight has developed a RESTful API that employs **Role-based Access Control (RBAC)** as its access control policy. Throughout the section, we will explore the API using different users with varying roles. Credentials associated with the **pentestercompany.com** domain are identified as supplier accounts, while those with **hackthebox.com** are identified as customer accounts.

For each user that we authenticate, they will have pre-assigned roles determined by the admin of **Inlanefreight E-Commerce Marketplace**. The admin has adopted a straightforward naming convention for roles: the roles share the same prefix as the resource to which they provide access to. For example, if a user has the role **Suppliers_GetAll**, it implies that the user has access to the endpoint that retrieves all supplier records (which, in this case, is **/api/v1/suppliers**).

Our objective is to report any vulnerabilities found to the admin of **Inlanefreight E-Commerce Marketplace**. Any discovered vulnerabilities will assist the admin in taking appropriate actions to secure the API. Each vulnerability is associated with a relevant **CWE** weakness.

Swagger API User Interface

Despite the frontend of **Inlanefreight E-Commerce Marketplace** still being in active development, the vulnerability scanner **Swagger** UI at the **/swagger** path (make sure to include it after the port of the spawned target machine). We will use it throughout the module to explore and assess the security of the marketplace's API, which includes over 60 endpoints.

Suppliers

Schemas

The key entities that the marketplace encompasses include **Customers**, **Products**, **Supplier-Companies**, and **Suppliers**. These entities interact with other entities as we progress through the sections.



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

+ 0 

There is only one endpoint belonging to the Roles group. Submit its path.

Submit your answer here...

+10 Streak pts

[← Previous](#)[Next →](#)[? Go to Questions](#)

Table of Contents

Introduction

[Introduction to API Attacks](#) [Introduction to Lab](#)

OWASP API Security Top 10

 [Broken Object Level Authorization](#) [Broken Authentication](#) [Broken Object Property Level Authorization](#) [Unrestricted Resource Consumption](#) [Broken Function Level Authorization](#) [Unrestricted Access to Sensitive Business Flows](#) [Server Side Request Forgery](#) [Security Misconfiguration](#) [Improper Inventory Management](#) [Unsafe Consumption of APIs](#)

